

Scenario 04 — CRA conformity mapping

The bridge between the **as-built security posture of Clone Systems' SEUXDR** and the **CRA framework as it is actually represented in CyberFort**.

Scenarios 01–03 map *seeded vulnerabilities* in a teaching target to framework controls. This scenario is different in kind: SEUXDR is a real product, so the mapping runs in **both directions** — the conformity evidence the manufacturer can legitimately claim, and the non-conformities that block a Declaration of Conformity. A real conformity assessment is not a bug list; it is a defensible position on every essential requirement, including the ones you pass.

The question texts quoted below are verbatim from the platform's **CRA conformity seed** (52 product-level questions, read from the live `CRA Extended` tenant on 2026-07-29). Every product claim is anchored to a file path in `t4.4_siem_ai_remediation @ 00a95ad`.

How the CRA framework is structured in CyberFort

CyberFort ships the Cyber Resilience Act as a built-in framework with two assessment types (**Conformity** and **Audit**) and an objective tree of Chapters → Articles → Annex I objectives → Vulnerability Handling objectives. Scoped to a single asset, the tree holds **30 objectives across 6 chapters**:

Chapter	Objectives	Content
Chapter I — General Provisions	2	Art. 1–2 (scope), Art. 6 + Annex I (essential requirements)
Chapter II — Obligations of Economic Operators	4	Art. 13 (manufacturers), Art. 14 (reporting), Art. 25 (internal processes), Art. 26 (guidance)
Chapter III — Conformity of the Products	1	conformity assessment procedure
Chapter V — Market Surveillance	2	Art. 52 + 54, Art. 70
ANNEX I	13	objectives <code>1</code> , <code>2</code> , <code>3a</code> – <code>3k</code> , grouped into seven subchapters
Vulnerability Handling	8	objectives <code>1</code> – <code>8</code> , grouped into three subchapters

The Annex I subchapters are *Secure Product Design and Development* (`1` , `2`), *Secure Configuration Management* (`3a`), *Access Control and Authentication* (`3b`), *Data Protection* (`3c` , `3d` , `3e`), *Availability and Resilience* (`3f` , `3g`), *Attack Surface and Incident Mitigation* (`3h` , `3i`), *Security Logging* (`3j`) and *Security Update Management* (`3k`). Vulnerability Handling splits into *Vulnerability Identification and Testing* (`1` – `3`), *Vulnerability Disclosure* (`4` – `6`) and *Security Update Distribution* (`7` – `8`).

Each objective carries pre-seeded **Objective Utilities** (the policy documents that would satisfy it), the **Policies** actually linked in the tenant with their approval state, an **Evidence** upload action, and a **Compliance Status** selector. The Conformity assessment sits alongside as a **52-question** natural-language questionnaire. The engineer answers the questionnaire; the objective tree is where the position is recorded and evidenced.

CYBERFORT

RESILIENT EUROPE

Dashboard

Assessments

Frameworks

Objectives

Assets / Products

Risks

Controls

Documents

Compliance Chain

Security Tools

Documentation

AI Assistant

gkoutidis

CRA Extended

Sign out

Objectives Checklist

AI Auto-selectExport PDF

Framework & Scope Selection

Select Framework *

CRA

Scope Type *

Asset / Product

Select Asset / Product

SEUXDR (Software Product)

Scope: Asset / Product - SEUXDR (Software Product)

Chapter II - Obligations of Economic Operators

4 objectives

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence
Internal Security Processes and Controls	Article 25 (Security Measures)	Manufacturers must put in place appropriate and proportionate internal processes and measures to ensure compliance with the CRA.	Information Security Policy, Product Cybersecurity Policy, Management Review Minutes, Information Security Objectives & Plan, Confidentiality Policy, Physical Security Policy, Secure Code Policy, Encryption Policy, Risk Management Policy, Risk Assessment Methodology	Risk Management Policy Approved Software Development Lifecycle Policy Approved Information Security Policy Approved Information Security Objectives And Plan Draft Product Cybersecurity Policy Draft Encryption Policy Review Risk Assessment Methodology Draft Management Review Minutes Draft Physical Security Policy Draft Confidentiality Policy Approved	Upload
Manufacturer Obligations and Responsibilities	Article 13 (Obligations of Manufacturers)	Manufacturers have comprehensive obligations, including ensuring products meet essential requirements, drawing up technical documentation, conducting conformity assessments, providing security updates, and handling vulnerabilities.	Information Security Policy, Organizational Roles, Responsibilities And Authorities, Product Registry Form, Vulnerability Management Policy, Incident Management Policy, Corrective Action Procedures, Product Lifecycle Management (PLM) Policy	Incident Management Policy Draft Information Security Policy Approved Vulnerability Management Policy Approved Organizational Roles Responsibilities And Authorities Draft Product Registry Form Draft Product Lifecycle Management Policy Draft Corrective Action Procedures Draft	Upload
User Documentation and Guidance	Article 26 (Guidance)	Manufacturers should provide users with clear and accessible instructions and information on the secure installation, operation, and maintenance of the product.	Product Registry Form, Information Security Policy, Secure Development Policy, Acceptable use Policy, Vulnerability Management Policy	Software Development Lifecycle Policy Approved Vulnerability Management Policy Approved Information Security Policy Approved Vulnerability Management Policy Approved Product Registry Form Draft	Upload
Vulnerability and Incident Reporting	Article 14 (Reporting of Actively Exploited Vulnerabilities and Incidents)	Manufacturers must report actively exploited vulnerabilities and serious cybersecurity incidents to ENISA and relevant CSIRTs within specified timelines.	Incident Management Policy, Corrective Action Procedures, External Communications Policy, Contact Procedure With Local Authorities	Incident Management Policy Draft Contact Procedure With Local Authorities Draft External Communications Policy Draft Corrective Action Procedures Draft	Upload

Chapter I - General Provisions

2 objectives

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	Completion
Essential Cybersecurity Requirements	Article 6 (Requirements for Products with Digital Elements) & Annex I (Essential Requirements)	Products with digital elements must meet essential cybersecurity requirements throughout their lifecycle, including security by design, vulnerability management, and incident prevention.	Product Registry Form, Secure Development Policy, Vulnerability Management Policy, Patch Management Policy, Logging And Monitoring Policy	- Patch Management Policy - Software Development Lifecycle Policy - Vulnerability Management Policy - Product Registry Form - Logging And Monitoring Policy	- Draft - Approved - Approved - Draft - Draft	Upload
Scope and Applicability	Article 1 - Subject Matter and Article 2: Scope	Understanding the applicability of the CRA to products with digital elements and key terminology.	Information Security Objectives and Plan, CRA Strategy Policy and Scope, Product Registry Form	- Password Policy - Information Security Policy - Information Security Objectives And Plan - Product Registry Form - CRA Strategy Policy And Scope	- Approved - Approved - Draft - Draft - Draft	Upload

ANNEX I

13 objectives

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	Completion
Access Control and Authentication	3b	ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems;	Password Policy, Encryption Policy, Access Control Policy, Log and Monitoring Policy, Awareness Policy	- Password Policy - Access Management Policy - Encryption Policy - Logging And Monitoring Policy - Awareness Policy	- Approved - Draft - Review - Draft - Draft	Upload
Attack Surface and Incident Mitigation	3h	Be designed, developed and produced to limit attack surfaces, including external interfaces	Secure Development Policy, Software Development Lifecycle (SDLC), Configuration Management Procedure, Change Management Policy, Vulnerability Management Procedure	- Software Development Lifecycle Policy - Vulnerability Management Policy - Configuration Management Policy - Change Management Policy	- Approved - Approved - Draft - Draft	Upload
Attack Surface and Incident Mitigation	3i	Be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;	Secure Development Policy, Vulnerability Management Procedure, Incident Response Plan, System Hardening Standards, Logging and Monitoring Policy	- Incident Management Policy - Software Development Lifecycle Policy - System Hardening Standards - Vulnerability Management Policy - Logging And Monitoring Policy	- Draft - Approved - Draft - Approved - Draft	Upload
		Minimize their own negative				

Availability and Resilience	3g	own negative impact on the availability of services provided by other devices or networks	Incident Response Plan, Logging and Monitoring Policy	● Incident Management Policy ● Logging And Monitoring Policy	● Draft ● Draft	Upload	Select
Availability and Resilience	3f	protect the availability of essential functions, including the resilience against and mitigation of denial of service attacks;	Monitoring and Logging Policy, Network Security Policy, Availability Policy	● Availability Policy ● Logging And Monitoring Policy ● Network Management Policy	● Draft ● Draft ● Draft	Upload	Select
Data Protection	3d	Protect the integrity of stored, transmitted or otherwise processed data, commands, programs and configuration against manipulation or modification	Change Management Policy, Encryption Policy, Secure Development Policy, Logging and Monitoring Policy, Access Control Policy	● Software Development Lifecycle Policy ● Access Management Policy ● Encryption Policy ● Logging And Monitoring Policy ● Change Management Policy	● Approved ● Draft ● Review ● Draft ● Draft	Upload	Select
Data Protection	3e	process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended use of the product ('minimisation of data');	Data Retention Policy, Data Protection Policy, Access Control Policy, Third-Party Data Processing Policy, Product Registry Entry	● Access Management Policy ● Data Classification Policy ● Data Retention Policy ● Product Registry Form	● Draft ● Draft ● Draft ● Draft	Upload	Select
Data Protection	3c	Protect the confidentiality of stored, transmitted or otherwise processed data through encryption	Encryption Policy	● Encryption Policy	● Review	Upload	Select
Secure Configuration Management	3a	Be delivered with a secure by default configuration, including the possibility to reset the product to its original state	Asset Management Policy, Secure Coding Policy, Password Policy, Encryption Policy, Information Security Policy, Configuration Management Policy	● Software Development Lifecycle Policy ● Password Policy ● Information Security Policy ● Encryption Policy ● Configuration Management Policy ● Asset Management Policy	● Approved ● Approved ● Approved ● Review ● Draft ● Draft	Upload	Select
Secure Product Design and Development	1	Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks	Comprehensive Secure Development Lifecycle (SDLC) policy document, Vulnerability Management Policy, Acceptable Use Policy	● Software Development Lifecycle Policy ● Vulnerability Management Policy ● Vulnerability Management Policy	● Approved ● Approved ● Approved	Upload	Select
Secure Product Design and Development	2	Products with digital elements shall be delivered without any known exploitable vulnerabilities	Vulnerability Management Policy, Patch Management Policy	● Patch Management Policy ● Vulnerability Management Policy	● Draft ● Approved	Upload	Select

Security Monitoring and Logging	3j	provide security related information by recording and/or monitoring relevant internal activity, including the access to or modification of data, services or functions;	Logging and Monitoring Policy, Privileged Access Management Procedure	- Access Management Policy - Logging And Monitoring Policy	• Draft • Draft	Upload Select
Security Update Management	3k	ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic updates and the notification of available updates to users.	Vulnerability Management Procedure, Secure Development Policy, Software Update and Patch Management Policy, Change Management Policy	- Risk Management Policy - Patch Management Policy - Software Development Lifecycle Policy - Vulnerability Management Policy - Change Management Policy	• Approved • Draft • Approved • Approved • Draft	Upload Select

Chapter V - Market Surveillance, Control of Products with Digital Elements Entering the Union Market and Union Safeguard Procedure

2 objectives

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	Comp
Continuous Evaluation and Improvement	Article 70 (Evaluation and Review)	The Commission will evaluate the CRA, highlighting the importance of ongoing performance assessment by economic operators.	Performance Measurement Policy, Management Review Procedure, Information Security Objectives & Plan, Information Security Policy, Information Security Communication Plan	- Information Security Policy - Information Security Objectives And Plan	• Approved • Draft	Upload Select
Market Surveillance and Compliance Monitoring	Article 52 (Market Surveillance Authorities) & Article 54 (Procedure at National Level for Products Presenting a Cybersecurity Risk)	Market surveillance authorities will monitor compliance, and procedures are in place for addressing non-compliant products.	Internal Audit Procedure, Corrective Action Procedures, Information Security Policy, Procedure For Control Of Documented Information, Management Review Procedure, Information Security Communication Plan	- Information Security Policy - Corrective Action Procedures	• Approved • Draft	Upload pa

Vulnerability Handling

8 objectives

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	C
		ensure that, where ..				

Security Update Distribution	8	security patches or updates are available to address identified security issues, they are disseminated without delay and free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken.	Security Patch Management Policy, Security Advisory Communication Procedure, Incident Response Plan, Vulnerability Disclosure Policy	● Incident Management Policy ● Patch Management Policy ● Vulnerability Management Policy ● Security Advisory Communication Procedure	● Draft ● Draft ● Approved ● Draft	Upload
Security Update Distribution	7	provide for mechanisms to securely distribute updates for products with digital elements to ensure that exploitable vulnerabilities are fixed or mitigated in a timely manner;	Patch Management and Update Policy, Secure Software Delivery Procedure, Change Management Policy, Monitoring and Logging Policy, Product Lifecycle and Support Policy	● Patch Management Policy ● Secure Software Delivery Procedure ● Logging And Monitoring Policy ● Product Lifecycle And Support Policy ● Change Management Policy	● Draft ● Draft ● Draft ● Draft ● Draft	Upload
Vulnerability Disclosure	5	put in place and enforce a policy on coordinated vulnerability disclosure;	Vulnerability Management Policy, Incident Response Plan	● Incident Management Policy ● Vulnerability Management Policy	● Draft ● Approved	Upload
Vulnerability Disclosure	6	take measures to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in third party components contained in that product, including by providing a contact address for the reporting of the vulnerabilities discovered in the product with digital elements;	Vulnerability Management Policy, Third-Party Security Policy	● Vulnerability Management Policy ● Vendor Management Policy	● Approved ● Draft	Upload
Vulnerability Disclosure	4	once a security update has been made available, publically disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements	Incident Response and Communication Plan, Security Communications Plan, Secure Development Policy	● Incident Management Policy ● Software Development Lifecycle Policy ● Security Communications Plan	● Draft ● Approved ● Draft	Upload

		affected, the impacts of the vulnerabilities, their severity and information helping users to remediate the vulnerabilities;					
Vulnerability Identification and Testing	3	apply effective and regular tests and reviews of the security of the product with digital elements;	Secure Development Lifecycle (SDLC) Policy, Vulnerability Management Policy	● Software Development Lifecycle Policy ● Vulnerability Management Policy	● Approved ● Approved	Upload	
Vulnerability Identification and Testing	2	In relation to the risks posed to the products with digital elements, address and remediate vulnerabilities without delay, including by providing security updates;	Vulnerability Management Procedure, Security Patch and Update Policy, Change Management Policy, Threat Intelligence and Monitoring Procedure	● Patch Management Policy ● Vulnerability Management Policy ● Change Management Policy	● Draft ● Approved ● Draft	Upload	
Vulnerability Identification and Testing	1	identify and document vulnerabilities and components contained in the product, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the product;	Product Registry Entry, Third-Party Software Policy, Secure Development Policy, Vulnerability Management Procedure, Supply Chain Risk Management Policy, Release Management Procedure	● Software Development Lifecycle Policy ● Vulnerability Management Policy ● Release Management Procedure ● Product Registry Form ● Vendor Management Policy	● Approved ● Approved ● Draft ● Draft ● Draft	Upload	

Chapter III - Conformity of the Products with Digital Elements

1 objective

Subchapter	Objective Title	Requirement Description	Objective Utilities	Policies	Evidence	Compliance Status
Conformity Assessment and Documentation	Article 28 (EU Declaration of Conformity) & Annex V (Technical Documentation)	Manufacturers must draw up an EU declaration of conformity and compile technical documentation demonstrating that the product meets the essential requirements.	EU Declaration of Conformity Template, Product Registry Form, Procedure For Control Of Documented Information	● Product Registry Form	● Draft Upload	● partially compliant

AI Compliance Suggestions



No AI suggestions yet. Click "Auto-select with AI" to generate compliance recommendations.

Two platform-specific notes that matter for reading the tables below:

- Questions **36** and **37** correspond to the secure-data-removal and secure-transfer limbs of Annex I. The platform's objective tree stops at **3k** and folds both into the *Data Protection* subchapter, so they are mapped here to **3e** and **3c** respectively.
- The engineer never sees "Annex I objective 3b" next to question 20 — only the natural-language text. The mapping in this document is what lets the assessor verify the right questions were answered against the right evidence.

Product classification

SEUXDR is an **Annex III important product with digital elements, Class I**, selectable in CyberFort under *Criticality* as the verbatim option **"Security information and event management (SIEM) systems"**.

The screenshot displays the CyberFort Asset Management interface. A modal window titled 'Add New Asset' is open, showing the 'Details' tab. The form contains the following fields and values:

- Asset Name:** SEUXDR
- Version:** 3.4
- Asset Type:** Software Product
- Status:** Active
- Economic Operator:** Manufacturer
- Criticality:** Security information and event management (SIEM)...
- CRA Vertical Profile:** Anti-Malware / Malware Detection Product
- License:** Proprietary - Clone Systems commercial licence, 5-year
- IP Address / IP Range / URL:** 45.132.135.12
- Justification:** Security information and event management (SIEM) system with automated AI-driven remediation. Listed in CRA Annex III as an important product with digital elements, Class I, therefore subject to Article 32(2) conformity assessment obligations.
- Description:** Self-hosted SIEM/XDR platform for SME and mid-market operators. Collects and correlates security telemetry from Windows, Linux and macOS endpoint agents over mTLS, and applies a locally hosted LLM (Ollama) to generate and execute automated remediation actions - IP blocking, process termination and malicious-file quarantine - without sending customer telemetry to a third-party cloud.
- SBOM (Software Bill of Materials):** CycloneDX 1.5 SBOM generated per release by Security Tools > SBOM Generator (Syft); top-level Go modules, npm packages and base images tracked per build.

At the bottom of the modal are 'Cancel' and 'Save Asset' buttons. The background shows a table of assets with columns for Name, Type, Status, Criticality, and Last Updated.

The classification is over-determined — three independent Annex III Class I limbs apply:

Limb	Evidence
SIEM system	Bundles Wazuh 4.11 SIEM inside its own image (<code>Dockerfile:53</code> , <code>startup.sh:19</code>); centralised multi-tenant event collection, storage and query (<code>manager/api/websocket/service/logstore.go:30-91</code> , <code>manager/routes/routes.go:68</code>); MITRE ATT&CK enrichment and STIX 2.1 export (<code>manager/handlers/stix_handler.go:11-52</code>); ships branded <code>SECUR-EU SIEM</code> (<code>manager_front/index.html:7</code>)
Intrusion detection and prevention system	Self-declared HIDS (<code>readme.md:3</code> , <code>CLAUDE.md:7</code>); prevention is implemented, not just detection — <code>BLOCK_IP</code> installs firewall DROP rules (<code>agent/active-response/firewall-drop.sh:142-143</code>)
Software that searches for, removes or quarantines malicious software	Malware-triggered <code>DELETE_FILE</code> on endpoints (<code>agent/active-response/delete-file.sh:32</code> , dispatch <code>agent/monitoring/monitoring.go:475</code>)

Three aggravating characteristics support arguing **Class II**, or at minimum documenting why Class I was chosen: the agent is a fleet-wide privileged remote-execution capability (`agent/monitoring/monitoring.go:446-484`); the manager **operates a real X.509 certificate authority** (RSA-4096, `IsCA: true` , `KeyUsageCertSign|CRLSign` — `manager/mtls/mtls.go:601-615`); and it generates and distributes agent installers with embedded private keys through an unauthenticated download endpoint (`manager/routes/routes.go:69-70`).

The practical consequence is the single most important output of the scope step: **an Annex III product cannot self-assess against Module A alone**. Article 32(2) requires a notified-body route (or full application of harmonised standards where available), and Annex I Part II vulnerability handling applies in full.

Part A — Conformity evidence, one card per claim

These are the positions Clone Systems can defend from code. They are the reason the pilot is worth running: a manufacturer who only files bugs has an incident report, not a conformity assessment.

Claim 1 — Modern authenticated encryption throughout, no legacy crypto anywhere

Where: `agent/comms/utils.go:93-99,124-129` · `manager/api/agentauthenticationservice/authentication_service.go:222-240` · `agent/storage/storage.go:36-40,70-75` · `manager/utils/dbutils.go:152-157` · key wrapping `agent/encryption/service/encryption/service.go:91,100` .

Substance: AES-GCM with a random per-message nonce for every encrypted payload; RSA-OAEP-SHA256 for key wrapping, not PKCS#1 v1.5. A repository-wide review found **no ECB, no unauthenticated CBC and no static IV**. Per-agent key isolation means compromise of one agent's key does not expose another's traffic (`manager/database/migrations/000001_init_mg.up.sql:66`).

Annex I objective	Conformity question the engineer answers
3c (<i>confidentiality through encryption</i>)	Q24 — "Do you use state-of-the-art mechanisms for encrypting relevant data at rest or in transit?"
3d (<i>integrity of data, commands, programs, configuration</i>)	Q25 — "Do you protect the integrity of stored, transmitted or otherwise processed data, commands, programs and configuration?"

Claim 2 — TLS 1.2 floor enforced in every server and client, with no agent-side bypass

Where: `manager/main.go:181–182,212–213` · `manager/mtls/mtls.go:244–245` · `agent/comms/tlsconfig.go:63–64,141–142` · `manager_front/nginx.conf:8` .

Substance: No downgrade path exists. The agent additionally **fails closed** if the CA PEM will not append (`agent/comms/tlsconfig.go:56–57`) and **validates CA and client certificate expiry before use** (`:111–113,136–138`). `InsecureSkipVerify` appears four times, all on manager→loopback backend calls (`OpenSearch :9200` , `Wazuh API :55000`) and never on an agent path.

Annex I objective	Conformity question the engineer answers
3c (<i>confidentiality</i>)	Q23 — "Do you protect the confidentiality of stored, transmitted or otherwise processed data through encryption?"
3h (<i>limit attack surfaces, external interfaces</i>)	Q32 — "Are your products designed, developed and produced to limit attack surfaces, including external interfaces?"

Claim 3 — Two-factor agent enrolment over mTLS on a dedicated, minimal listener

Where: `manager/main.go:176–183` (`tls.RequireAndVerifyClientCert` , CA pool `:154–162`) · `manager/api/registrationservice/registration_service.go:78,86,88–92` · rate limiter `manager/middlewares/ratelimiter.go:14–16,32` · key generation `manager/helpers/helpers.go:467–478` .

Substance: Enrolment requires a valid X.509 client certificate **at the transport** and an organisation API key plus group licence key **in the payload**, cross-validated for org/group consistency. API keys are 256-bit from `crypto/rand` . The listener on `:8081` exposes exactly two routes, architecturally separated from the operational API on `:8443` — genuine port separation by trust level.

Annex I objective	Conformity question the engineer answers
3b (<i>protection from unauthorised access</i>)	Q20 — "Do you ensure protection from unauthorized access by appropriate control mechanisms?" (<i>supports the enrolment limb only — see Non-conformity 1</i>)
3h (<i>limit attack surfaces</i>)	Q32 — "Are your products designed, developed and produced to limit attack surfaces, including external interfaces?"

Claim 4 — Availability and resilience: failed-alert queue, dead-letter queue, resume-after-restart

Where: schema `manager/database/migrations/000005_failed_alert_queue.up.sql:3–104` · `manager/api/failedAlertManager/failed_alert_manager.go:133–139` · state resume `manager/api/activeresponseservice/active_response_service.go:560–612` · keepalive

manager/handlers/handlers.go:18–27 · reaper
manager/api/connectionmanager/connection_manager.go:473–504 .

Substance: Alerts that fail processing retry with exponential backoff and, after three attempts, move to a dead-letter queue for analyst review rather than being silently lost. A manager restart resumes from the last completed timestamp instead of losing or re-processing the alert window. Bounded channels prevent unbounded memory growth; stale WebSocket connections are reaped on a 54 s ping / 60 s pong-wait cycle with a 512 KB read limit. This is the best-engineered subsystem in the product.

Annex I objective	Conformity question the engineer answers
3f (<i>availability of essential functions, DoS resilience</i>)	Q29 — "Do you protect the availability of essential and basic functions, also after an incident?" · Q30 — "Do you implement resilience and mitigation measures against denial-of-service attacks?"

Claim 5 — Security-event recording, including a full AI decision narrative

Where: manager/logging/logging.go:31–52 · correlation IDs manager/middlewares/logger.go:24–49 · manager/database/migrations/000004_soc_analyst_storage.up.sql:2–22 · written manager/api/socanalystservice/soc_analyst_service.go:244–256 · command lifecycle 000003_active_response_persistence.up.sql:2–19 .

Substance: Structured JSON logging with a per-request UUID echoed as X-Request-Id , separated by trust domain into server.log , registrations.log and mtls.log . Every AI analysis persists its reasoning , extracted_evidence , severity_factors , mitre_tactics and the complete react_history iteration log — **explainability that is better than typical for this product class**. Every remediation command persists status, stdout/stderr, message and executed_at .

Annex I objective	Conformity question the engineer answers
3j (<i>security-relevant information recording</i>)	Q34 — "Do you provide security-related information by recording and monitoring relevant internal activity?"
3j (<i>monitoring access/modification</i>)	Q35 — "Do you monitor access to or modification of data, services or functions with an opt-out mechanism for users?" (<i>monitoring limb only; the opt-out is not evidenced</i>)

Claim 6 — Structural blast-radius limitation: remediation is strictly per-agent

Where: manager/api/messageprocessor/message_processor.go:430 · dispatch gating :441–449 · manager/handlers/agent_actions.go:417–420 · NOT_FOUND sentinel :1190 · duplicate suppression manager/api/socanalystservice/react_service.go:389–394 .

Substance: Each alert resolves to exactly one agent, and **no fleet-wide or group-wide action primitive exists anywhere in the codebase**. A single bad AI decision cannot cascade across the estate. This limit is structural rather than configurational, which makes it a much stronger claim than a policy setting. Actions dispatch only to agents with a live verified connection, and an unresolvable target diverts to manual review instead of guessing.

Annex I objective	Conformity question the engineer answers
3g (<i>minimise negative impact on other devices/networks</i>)	Q31 — "Do you minimize the negative impact by your products on the availability of services provided by other devices or networks?"

Annex I objective	Conformity question the engineer answers
3i (<i>reduce impact of an incident</i>)	Q33 — "Are your products designed to reduce the impact of an incident using appropriate exploitation mitigation mechanisms?"

Claim 7 — Secure-by-default AI safety posture and fail-fast configuration validation

Where: `manager/manager.yaml:49` (`action_mode: "manual_only"`) enforced at `manager/api/messageprocessor/message_processor.go:1176,1191` · config validation `manager/config/config.go:252-288` .

Substance: On the as-shipped configuration **no AI-initiated destructive action reaches an endpoint without a human step**; analyses land as `manual_action_required` . Configuration is validated at load with fail-fast semantics, rejecting out-of-range rule levels, non-positive batch sizes, negative cooldowns and any illegal `action_mode` . This is the right default for an autonomous-remediation product and should be presented as a deliberate design choice.

Annex I objective	Conformity question the engineer answers
3a (<i>secure by default configuration</i>)	Q14 — "Are your products made available on the market with a secure by default configuration?"

⚠ **The claim has three documented limits** and must be answered *Partially*, not *Yes*: the operator endpoint never reads `ACTION_MODE` (Non-conformity 1); `retryCommandsForAgent` does not read it either (`message_processor.go:1377-1440`); and `manager/config/config.go:384-386` **defaults to "automatic" when the key is unset**, which the shipped `manager/test.yaml:39-44` profile does. A secure default that fails open when absent is a partial control.

Claim 8 — Local-only AI inference: customer telemetry never leaves the deployment

Where: `manager/manager.yaml:71-74` · `manager/api/socanalystservice/llm_service.go:142` · `CyberGuard_Stripped_Documentation.md:39` .

Substance: The LLM runs in-network via Ollama (`phi4:14b`). Endpoint log content — which routinely contains usernames, hostnames, IPs, file paths and command lines — is **never sent to a third-party cloud model**. For an EU-market security product this is a demonstrable data-protection property and a commercial differentiator.

Annex I objective	Conformity question the engineer answers
3c (<i>confidentiality</i>)	Q23 — "Do you protect the confidentiality of stored, transmitted or otherwise processed data through encryption?"
3e (<i>data minimisation</i>)	Q28 — "Do you process only data that is adequate, relevant and limited to what is necessary for the intended purpose?" (<i>no third-party disclosure limb only — see Non-conformity 5</i>)

Claim 9 — Agent update integrity: SHA-256 verification with automatic rollback

Where: checksum computed `manager/api/configuration-service/configuration_service.go:916-917` → served `manager/handlers/agent_actions.go:271` → verified `agent/agentd/update.go:224-`

250 · rollback agent/main.go:288–293,304–309,349–352 · semver floor
manager/api/updateservice.go/update_service.go:115–145 .

Substance: Downloaded agent binaries are SHA-256 verified before installation. The updater backs up the current binary, restores SELinux `bin_t` context on Linux, and **rolls back on either replace failure or restart failure** — a real integrity-preservation control. Staged-rollout and version-deactivation controls exist in the schema. Client certificates are short-lived (1 month, 7-day refresh) with automated re-signing (`manager/mtls/mtls.go:886–894`).

Objective	Conformity question the engineer answers
Annex I 3k (<i>vulnerabilities addressable through updates</i>)	Q16 — "Do you ensure that vulnerabilities can be addressed through security updates?"
Vuln-Handling 7 (<i>secure update distribution</i>)	Q47 — "Do you provide mechanisms to securely distribute updates for your products with digital elements?"

△ Answer both *Partially*. Integrity verification **fails open** — `agent/agentd/update.go:225–228` installs the binary when the expected checksum is empty, and the field is commented out in two of three manager response paths. Nothing is **signed**: no GPG, Authenticode, notarisation or Sigstore anywhere. A hash delivered over the same channel as the binary defends against corruption, not against a compromised manager. And the manager itself has **no update mechanism at all**.

Part B — Non-conformities, one card per finding

Non-conformity 1 — Unauthenticated remote file deletion, process termination and network blocking across the agent fleet

Where: route registered with no auth middleware — `manager/routes/routes.go:86` (the `/api` group applies only `CustomLogger`, `:64–65`); handler `manager/handlers/agent_actions.go:357–491` validates the action verb at `:385–388` and nothing else, dispatching at `:454`; endpoint executes `rm -f "${FILEPATH}"` as root (`agent/active-response/delete-file.sh:32`).

Detected by: **Semgrep** (missing-authentication patterns) + manual route review + the product's own **Postman collection**, which declares `auth: None` on all 31 requests.

Substance: Any party with TCP reach to port 8443 can delete any file, kill any process or firewall-block any IP on any connected agent — unauthenticated, unrate-limited (the limiter covers only `/api/register`) and **unattributed**, because no operator identity is recorded (`:424–435`). It bypasses `action_mode: manual_only` entirely, since the handler never reads `ACTION_MODE`. This is a shipped, remotely exploitable vulnerability, which is what makes Q13 answerable only as *No*.

Objective	Conformity question the engineer answers
Annex I 3b (<i>protection from unauthorised access</i>)	Q20 — "Do you ensure protection from unauthorized access by appropriate control mechanisms?"
Annex I 2 (<i>no known exploitable vulnerabilities</i>)	Q13 — "Are your products with digital elements delivered without any known exploitable vulnerabilities?"

Objective	Conformity question the engineer answers
Annex I 3d (<i>protection against unauthorised modification</i>)	Q26 — "Do you protect against manipulation or modification not authorized by the user?"

Non-conformity 2 — No user authentication, authorisation or accountability anywhere in the product

Where: `manager/middlewares/middleware.go` is 13 lines and defines no auth function; no login route in `manager/routes/routes.go`; no `users` / `roles` / `sessions` tables in any of the five migrations. JWT code exists but is dead (`manager/config/auth_config.go:102-153`, zero call sites); the password validator is dead (`manager/validators/validators.go`, zero importers).

Detected by: Semgrep + migration review + `grep` for call sites.

Substance: All 22 TLS routes are open, including `POST /api/create/org`, `POST /api/create/agent`, `GET /api/download/agent` (which hands out installers containing embedded private keys) and `POST /api/view/alerts` (full endpoint log content). This was removed deliberately on 2025-10-29 and is documented as such; `CLAUDE.md:18-19,45` still claims RBAC and JWT are present, so the documentation contradicts the artefact.

Objective	Conformity question the engineer answers
Annex I 3b (<i>authentication, identity, access management</i>)	Q21 — "Do you implement authentication, identity or access management systems?"
Annex I 3b (<i>reporting unauthorised access</i>)	Q22 — "Do you report on possible unauthorized access?"
Chapter II, Art. 25 (<i>internal processes</i>)	Q10 — "Do you systematically document relevant cybersecurity aspects concerning your products with digital elements?"

Non-conformity 3 — Unvalidated LLM output becomes a root-privileged destructive command argument

Where: the unbroken chain is model output →

`manager/api/socanalystservice/react_service.go:318-320` → `ActionDecision.Target` :397-402 → `DB soc_analyst_service.go:217-226` → `message_processor.go:1257-1266` → encrypted WebSocket frame `connection_manager.go:301-310` → `agent/monitoring/loglisten.go:479` → `ExecuteAction` `agent/monitoring/monitoring.go:446` → `executeEmbeddedScript(..., actionMsg.Target)` → `rm -f` / `pkill -x` / `pfctl`.

Detected by: manual data-flow review. **The only validation of the target is non-emptiness** — `react_service.go:99-101` and `agent/monitoring/monitoring.go:463-467`.

Substance: No IP validation for `BLOCK_IP`, no path canonicalisation or protected-path denylist for `DELETE_FILE`, no PID or protected-process list for `KILL_PROCESS`, no length limit, no newline stripping.

Prompt injection is unmitigated: attacker-controlled log text is interpolated raw into the prompt via `text/template` (`prompt_service.go:206`), so anyone who can write a log line — a crafted User-Agent, filename or SSH username — can influence which host action runs. Up to three distinct actions may be emitted per alert. The documented agent-side whitelist, dangerous-pattern blocklist and execution timeout (`agent/helpers/helpers.go:523-583,467-472`) protect a **different, dead code path** and never run on the live one, which has no timeout at all.

Objective	Conformity question the engineer answers
Annex I 1 (<i>appropriate level of cybersecurity based on risks</i>)	Q12 — "Are your products with digital elements designed, developed and produced to ensure an appropriate level of cybersecurity based on the risks?"
Annex I 3d (<i>integrity of commands and programs</i>)	Q25 · Q26
Annex I 3i (<i>reduce impact of an incident</i>)	Q33 — "Are your products designed to reduce the impact of an incident using appropriate exploitation mitigation mechanisms?"

Non-conformity 4 — The entire Annex I Part II apparatus is absent

Where: no `SECURITY.md` ; `readme.md:394` contains the literal empty placeholder `contact []` or open an issue ; `CyberGuard_Stripped_Documentation.md:893` points at `github.com/SecureEU/seuxdr/issues` , a **different repository** from the actual remote. No CycloneDX or SPDX artefact. No `.github/` , `.gitlab-ci.yml` or any CI configuration. No `govulncheck` , `trivy` , `grype` , `osv-scanner` , `npm audit` or Dependabot. No `CHANGELOG.md` . **No git tags at all** — eight unstructured commits on `main` .

Detected by: **OSV Dependency Check** (surfaces the unscanned dependency tree) + **SBOM Generator** (produces the missing artefact) + repository review.

Substance: The closest thing to a component inventory is `licenses/credits.txt` , a hand-maintained 26-entry list that still contains the template placeholder `<Include your full license text here>` , declares MIT while `readme.md:390` points at Apache-2.0, and omits nearly all ~100 indirect Go modules and **all** front-end dependencies. Six of eight Vulnerability Handling objectives have no supporting artefact whatsoever.

Objective	Conformity question the engineer answers
Vuln-Handling 1 (<i>component inventory, SBOM</i>)	Q38 — "Do you identify and document vulnerabilities and components contained in your products with digital elements?" · Q39 — "Do you draw up a software bill of materials in a commonly used and machine-readable format?" · Q40 — "Does your software bill of materials cover at least the top-level dependencies of the products?"
Vuln-Handling 3 (<i>regular tests and reviews</i>)	Q41 — "Do you apply effective and regular tests and reviews of the security of your products with digital elements?"
Vuln-Handling 4 (<i>public disclosure of fixed vulnerabilities</i>)	Q42 · Q43
Vuln-Handling 5 (<i>coordinated vulnerability disclosure policy</i>)	Q44 — "Do you have a policy on coordinated vulnerability disclosure in place and enforced?"
Vuln-Handling 6 (<i>contact address</i>)	Q45 · Q46 — "Do you provide a contact address for reporting vulnerabilities discovered in your products?"
Vuln-Handling 2 / 8 (<i>timely remediation, dissemination</i>)	Q48 · Q50 · Q52

Non-conformity 5 — No data minimisation over endpoint log content

Where: raw log lines persisted verbatim to `soc_analyst_analyses.full_log` (`000004_soc_analyst_storage.up.sql:11`); written to **world-readable** queue files at mode `0644` (`manager/api/websocket/service/logstore.go:36,72`); interpolated into LLM prompts (`prompt_service.go:206`).

Detected by: Semgrep (permissive file modes) + schema review.

Substance: This content routinely contains usernames, hostnames, source IPs, file paths and command lines — personal data under GDPR. There is no pseudonymisation, no field redaction, and **no retention policy at all** on `soc_analyst_analyses` or `active_response_commands`; both grow without bound. Queue-file rotation exists (3 most recent daily files per agent, `manager/crons/log_cleanup.go:89-106`) and is the one genuine minimisation control.

Objective	Conformity question the engineer answers
Annex I 3e (<i>data minimisation</i>)	Q28 — "Do you process only data that is adequate, relevant and limited to what is necessary for the intended purpose?"
Annex I 3c (<i>confidentiality of stored data</i>)	Q23 — "Do you protect the confidentiality of stored, transmitted or otherwise processed data through encryption?"

Non-conformity 6 — Secrets exposure: committed credential, plaintext KEK, world-readable keys

Where: live Wazuh/OpenSearch admin credential `admin / S1lMfWxh1HB6SbKg.9fmkoq.P5W+07M5` committed in three tracked files (`main.go:176-177`, `stix_service_integration_test.go:167-168`, `opensearch_service_integration_test.go:256-257`) · group KEK RSA private key stored **unwrapped** in the unencrypted SQLite DB (`configuration_service.go:130,134,142` → `groups.key_encryption_key`) · private keys written `0644` via `os.Create` (`manager/helpers/helpers.go:314-337,137-152`; `keys.json` explicitly `0644` at `configuration_service.go:957,1016`) · storage and cert directories created `0777` (`manager/main.go:36,53`) · **enrolment API key and licence key logged in cleartext** (`manager/handlers/agent_actions.go:62`).

Detected by: Semgrep `hardcoded-password` / permissive-permissions rules.

Substance: Because the KEK sits unwrapped beside the `agents.encryption_key` values it protects, the per-agent key wrapping provides **no protection against file-level database theft**. The `0777` directories and `0644` key files mean any local user on the manager host can read the PKI.

Objective	Conformity question the engineer answers
Annex I 3a (<i>secure by default</i>)	Q14 — "Are your products made available on the market with a secure by default configuration?"
Annex I 3c (<i>confidentiality of stored data</i>)	Q23 · Q24
Annex I 2 (<i>no known exploitable vulnerabilities</i>)	Q13

Non-conformity 7 — Outdated and unpinned dependencies, unpinned base images

Where: `go.mod:5-35` — `golang-migrate v3.5.4+incompatible` (2018; upstream is v4), `gorilla/websocket v1.4.2` (2020 — this carries the remediation command channel), `patrickmn/go-cache v2.1.0+incompatible` (2019), `kardianos/service` and `tkanos/gonfig` pinned to 2021 commits with no tagged release, `golang/mock` and `pkg/errors` archived upstream. `manager_front/package.json:13,17,18` ships **three faker libraries in production dependencies**, including the sabotaged `faker@6.6.6`. `Dockerfile:1` uses `redhat/ubi9` with **no tag at all**; `docker-compose.yml:36` uses `ollama/ollama:latest`. **Not one image is digest-pinned.** `manager_front/Dockerfile:11` runs `npm install --frozen-lockfile` — a Yarn flag that is a no-op for npm, so the lockfile is not enforced.

Detected by: **OSV Dependency Check** on `go.mod` and `package-lock.json` + **SBOM Generator** (Syft) on the container images.

Substance: Compounded by Non-conformity 4 — with no dependency scanning in the repository, the manufacturer has no mechanism to learn that any of these carry advisories. The Wazuh installer and Go toolchain are also fetched and executed **without checksum or signature verification** (`Dockerfile:13-22,53`).

Objective	Conformity question the engineer answers
Annex I 2 (no known exploitable vulnerabilities)	Q13
Vuln-Handling 1 (identify and document components)	Q38 · Q39 · Q40
Vuln-Handling 2 (remediate without delay)	Q48 — "Do you ensure vulnerabilities are fixed or mitigated in a timely manner through updates?"

Non-conformity 8 — Safety controls that are configured, validated, documented and never enforced

Where: each verified to have no enforcement site — `min_rule_level` (`manager.yaml:30`, used only to build a prompt string at `message_processor.go:415`), `max_alerts_batch` (`:31`, query hard-codes `"size": 10000` at `opensearch_service.go:110`), `cooldown_period` (`:32`, no timestamp comparison or dedup key anywhere), `command_timeout` (`:33`, hard-coded 30 at `message_processor.go:1214`), `confidence_thresholds` (`:55-67`, **not in the config struct at all** — zero non-test hits for `confidence`), `analysis_timeout` (`:51`, overridden by a hard-coded 60 s at `:1065`), `llm.temperature` / `max_tokens` (`:77-78`, silently ignored for Ollama), `fallback_to_rules` (`:53`, plumbed and never read).

Detected by: manual configuration-to-code tracing.

Substance: The net effect is that **every alert of any severity that resolves to a connected agent is sent to the LLM and may yield up to three host actions, with no cooldown, no batch cap and no confidence gate**. For a regulatory submission this is the most dangerous class of finding, because it invites an assessor to accept assurance the artefact does not provide — and it undermines the credibility of the eight genuine claims in Part A.

Objective	Conformity question the engineer answers
Annex I 1 (<i>appropriate cybersecurity based on risks</i>)	Q12
Annex I 3a (<i>secure by default</i>)	Q14
Chapter II, Art. 13 (<i>technical documentation accuracy</i>)	Q8 · Q10

Non-conformity 9 — No risk assessment, no support-period declaration, no technical documentation

Where: no threat model, no attack-surface analysis, no data-flow diagram, no risk-assessment artefact anywhere in the repository. No `CHANGELOG.md`, no support-lifecycle or EOL statement, no declared support period. `agent_versions.release_notes` is seeded with the placeholder `'Bug fixes and improvements'` (`000001_init_mg.up.sql:57`).

Detected by: repository review against the CRA Technical File page checklists.

Substance: CRA Article 13 requires the cybersecurity risk assessment to be **drawn up, documented, kept updated during the support period, and included in the technical documentation** placed on the market. None of the nine questions in that block (Q1–Q9) has a supporting artefact. The CRA also requires a support period of **at least five years**; SEUXDR declares none. This is the block the pilot most directly fixes — the CyberFort risk register, objective tree and technical-file pages *are* the missing documentation, which is why the pilot's output is itself Annex V evidence.

Objective	Conformity question the engineer answers
Chapter II, Art. 13 (<i>manufacturer obligations</i>)	Q1 – Q9 (all nine risk-assessment questions)
Annex I 3k (<i>security updates</i>)	Q17 · Q18 · Q19
Vuln-Handling 8 (<i>advisory messages with updates</i>)	Q52 — "Do you accompany security updates with advisory messages providing users with relevant information?"

Annex I and Vulnerability Handling coverage matrix

Every one of the 30 objectives in the SEUXDR scope is addressed by this pilot — that is the point of a conformity assessment as opposed to a penetration test. The matrix records the **baseline position** established on 2026-07-29.

Objective	Title (paraphrased)	Baseline	Evidence / reason
1	Appropriate level of cybersecurity based on the risks	No	Non-conformities 1, 3, 8 — unauthenticated destructive endpoint and unvalidated LLM output
2	Delivered without known exploitable vulnerabilities	No	Non-conformity 1 is remotely exploitable as shipped; dependency tree unscanned (7)
3a	Secure by default configuration, resettable	Partially	Claim 7 (<code>manual_only</code> , fail-fast config) vs. fail-open default, <code>0777</code> dirs, privileged container

Objective	Title (paraphrased)	Baseline	Evidence / reason
3b	Protection from unauthorised access	No	Claim 3 covers agent enrolment only; Non-conformities 1 and 2 defeat the operational API
3c	Confidentiality through encryption	Partially	Claims 1, 2, 8 in transit; unencrypted SQLite, plaintext KEK, 0644 logs at rest (5, 6)
3d	Integrity of data, commands, programs, configuration	Partially	Claim 1 AEAD gives transit integrity; commands unsigned, no replay protection (Non-conformity 3)
3e	Data minimisation	No	Non-conformity 5 — raw log content persisted verbatim, no redaction, no retention on AI tables
3f	Availability of essential functions, DoS resilience	Yes	Claim 4 — failed-alert queue, DLQ, resume-after-restart, keepalive reaper
3g	Minimise negative impact on other devices/networks	Partially	Claim 6 per-agent scoping; but BLOCK_IP has no TTL and no reachable UNBLOCK_IP
3h	Limit attack surfaces, external interfaces	Partially	Claims 2, 3 port separation; undermined by privileged container and published Ollama port
3i	Reduce impact of an incident (exploit mitigation)	Partially	Claim 6 + update rollback; no sandboxing, temp-file TOCTOU, no protected-path denylist
3j	Security-relevant information recording	Yes	Claim 5 — structured logging, correlation IDs, full AI reasoning trail, STIX export
3k	Vulnerabilities addressable through security updates	Partially	Claim 9 agent channel with rollback; manager has no update mechanism, verification fails open
VH-1	Identify and document components (SBOM)	No	Non-conformity 4 — no SBOM; credits.txt incomplete and self-contradictory
VH-2	Address and remediate vulnerabilities without delay	No	Non-conformity 4 — no CI, no scanning, no tags, no changelog, no SLA
VH-3	Effective and regular security tests and reviews	No	Non-conformity 4 — no automated test run, no pen-test records. This pilot is the first review
VH-4	Public disclosure of fixed vulnerabilities	No	Non-conformity 4 — no advisory channel
VH-5	Coordinated vulnerability disclosure policy	No	Non-conformity 4 — no SECURITY.md
VH-6	Facilitate vulnerability sharing, contact address	No	Non-conformity 4 — readme.md:394 has an empty placeholder; docs cite the wrong repository
VH-7	Secure update distribution mechanisms	Partially	Claim 9 — SHA-256 over TLS with rollback, but fails open and nothing is signed
VH-8	Updates disseminated without delay, free, with advisories	No	Non-conformity 9 — no release process; release_notes is a placeholder

Objective	Title (paraphrased)	Baseline	Evidence / reason
Ch. I	Scope and essential requirements (2 objectives)	Partially	Scope determined and classification justified by this pilot; essential requirements not met
Ch. II	Economic-operator obligations (4 objectives)	No	Non-conformity 9 — no risk assessment, no technical documentation, no Art. 14 reporting procedure
Ch. III	Conformity of the product (1 objective)	No	Annex III Class I requires a notified-body route; none engaged
Ch. V	Market surveillance (2 objectives)	No	No internal audit procedure or corrective-action process linked to the product

Coverage summary: 2 objectives **Yes**, 10 **Partially**, 18 **No** — 2 Yes and 7 Partially across the 13 Annex I objectives, 1 Partially across the 8 Vulnerability Handling objectives, and Chapter I's 2 objectives Partially. Across the 52 conformity questions the baseline is **2 Yes / 19 Partially / 31 No**. Every one of the 30 objectives is evidenced either way, so the assessment is complete even though the product is not conformant.

i The **7%** figure is what the platform's EU Declaration of Conformity page displays at baseline. It aggregates across every product registered in the tenant (270 CRA objectives, 30 compliant, 1 assessment, 0 completed) and weights 60% objective compliance against 40% assessment completion. Scoped to SEUXDR alone the position is **2 of 30 objectives compliant with the conformity assessment unstated** — report both numbers, because the aggregated one is the one on screen.

A complete assessment showing a low score is a regulatory asset; an incomplete assessment showing nothing is a liability.

The 52 conformity questions — recommended baseline answers

This is the working sheet. Question numbers match the position in the CyberFort UI (paginated 10 per page). Answers are the defensible baseline for the as-built stripped variant; the *Evidence to attach* column names the artefact the engineer uploads.

#	Question (verbatim from CyberFort)	Answer	Objective	Evidence to attach
1	Have you undertaken an assessment of the cybersecurity risks associated with your product with digital elements?	No	Ch. II Art. 13	The pilot risk register itself is the first one
2	Do you take the outcome of the cybersecurity risk assessment into account during the planning, design, development, production, delivery and maintenance phases?	No	Ch. II Art. 13	No SDLC gate evidenced; no CI
3	Is your cybersecurity risk assessment documented and updated as appropriate during the support period?	No	Ch. II Art. 13	No support period declared

#	Question (verbatim from CyberFort)	Answer	Objective	Evidence to attach
4	Does your cybersecurity risk assessment comprise an analysis based on the intended purpose and reasonably foreseeable use of the product?	No	Ch. II Art. 13	No threat model in repository
5	Does your risk assessment take into account the conditions of use, operational environment, and assets to be protected?	No	Ch. II Art. 13	No attack-surface analysis
6	Does your risk assessment consider the length of time the product is expected to be in use?	No	Ch. II Art. 13	No EOL or support-lifecycle statement
7	Does your cybersecurity risk assessment indicate whether and how the security requirements are applicable to your product?	No	Ch. II Art. 13	Objective tree provides this once populated
8	Do you include the cybersecurity risk assessment in the technical documentation when placing the product on the market?	No	Ch. II Art. 13	Technical File pages are empty at baseline
9	Where certain essential cybersecurity requirements are not applicable, do you include clear justification in the technical documentation?	No	Ch. II Art. 13	No N/A justifications recorded
10	Do you systematically document relevant cybersecurity aspects concerning your products with digital elements?	Partially	Ch. II Art. 25	Extensive docs exist but contradict the code (Non-conformity 8)
11	Do you document vulnerabilities of which you become aware and relevant information provided by third parties?	No	VH-1	No advisory tracking, no CVE process
12	Are your products with digital elements designed, developed and produced to ensure an appropriate level of cybersecurity based on the risks?	No	Annex I 1	Non-conformities 1, 3, 8
13	Are your products with digital elements delivered without any known exploitable vulnerabilities?	No	Annex I 2	Non-conformity 1 + OSV scan output
14	Are your products made available on the market with a secure by default configuration?	Partially	Annex I 3a	Claim 7 vs. Non-conformity 6; Semgrep permissive-permissions findings
15	Do you provide the possibility to reset the product to its original state?	Partially	Annex I 3a	<code>clear-db.sh</code> , <code>delete-certs.sh</code> — operator scripts, not a product feature
16	Do you ensure that vulnerabilities can be addressed through security updates?	Partially	Annex I 3k	Claim 9; manager has no update path
17	Are automatic security updates installed within an appropriate timeframe enabled as a default setting?	Partially	Annex I 3k	Agent polls (<code>update.go:265</code> , a 10 s defect); manager none

#	Question (verbatim from CyberFort)	Answer	Objective	Evidence to attach
18	Do you provide a clear and easy-to-use opt-out mechanism for automatic updates?	No	Annex I 3k	Not evidenced
19	Do you notify users of available updates with the option to temporarily postpone them?	No	Annex I 3k	<code>release_notes</code> placeholder; no notification
20	Do you ensure protection from unauthorized access by appropriate control mechanisms?	No	Annex I 3b	Non-conformities 1, 2
21	Do you implement authentication, identity or access management systems?	No	Annex I 3b	Non-conformity 2 — removed 2025-10-29
22	Do you report on possible unauthorized access?	Partially	Annex I 3b	Claim 5 logging; no user auth to fail, no alerting
23	Do you protect the confidentiality of stored, transmitted or otherwise processed data through encryption?	Partially	Annex I 3c	Claims 1, 2, 8 vs. Non-conformities 5, 6
24	Do you use state-of-the-art mechanisms for encrypting relevant data at rest or in transit?	Partially	Annex I 3c	In transit yes (Claim 1); at rest no
25	Do you protect the integrity of stored, transmitted or otherwise processed data, commands, programs and configuration?	Partially	Annex I 3d	Claim 1; commands unsigned, no replay protection
26	Do you protect against manipulation or modification not authorized by the user?	No	Annex I 3d	Non-conformity 1
27	Do you report on corruptions of data, commands, programs and configuration?	No	Annex I 3d	Not evidenced
28	Do you process only data that is adequate, relevant and limited to what is necessary for the intended purpose?	No	Annex I 3e	Non-conformity 5
29	Do you protect the availability of essential and basic functions, also after an incident?	Yes	Annex I 3f	Claim 4 — DLQ schema + resume-after-restart
30	Do you implement resilience and mitigation measures against denial-of-service attacks?	Partially	Annex I 3f	Bounded channels, read limits; rate limiter covers only <code>/api/register</code>
31	Do you minimize the negative impact by your products on the availability of services provided by other devices or networks?	Partially	Annex I 3g	Claim 6; no block TTL, no reachable unblock
32	Are your products designed, developed and produced to limit attack surfaces, including external interfaces?	Partially	Annex I 3h	Claims 2, 3; privileged container, published Ollama port
33	Are your products designed to reduce the impact of an incident using appropriate exploitation mitigation mechanisms?	Partially	Annex I 3i	Claim 6 + rollback; no sandboxing or denylist

#	Question (verbatim from CyberFort)	Answer	Objective	Evidence to attach
34	Do you provide security-related information by recording and monitoring relevant internal activity?	Yes	Annex I 3j	Claim 5
35	Do you monitor access to or modification of data, services or functions with an opt-out mechanism for users?	Partially	Annex I 3j	Monitoring yes; opt-out not evidenced
36	Do you provide the possibility for users to securely and easily remove all data and settings on a permanent basis?	Partially	Annex I 3e	Reset scripts + log-retention cron; not user-facing
37	Where data can be transferred to other products or systems, do you ensure this is done in a secure manner?	Partially	Annex I 3c	STIX 2.1 export over TLS, but the API is unauthenticated
38	Do you identify and document vulnerabilities and components contained in your products with digital elements?	No	VH-1	Non-conformity 4; OSV + SBOM Generator output
39	Do you draw up a software bill of materials in a commonly used and machine-readable format?	No	VH-1	No SBOM ships. Fix in Step 3 of the runbook
40	Does your software bill of materials cover at least the top-level dependencies of the products?	No	VH-1	Same
41	Do you apply effective and regular tests and reviews of the security of your products with digital elements?	No	VH-3	No CI, no pen-test records
42	Once a security update is made available, do you share and publicly disclose information about fixed vulnerabilities?	No	VH-4	No advisory channel
43	Do you provide a description of vulnerabilities, affected products, impacts, severity and remediation information?	No	VH-4	No advisories published
44	Do you have a policy on coordinated vulnerability disclosure in place and enforced?	No	VH-5	No SECURITY.md
45	Do you facilitate the sharing of information about potential vulnerabilities in your product and third-party components?	No	VH-6	No channel; SBOM absent
46	Do you provide a contact address for reporting vulnerabilities discovered in your products?	No	VH-6	readme.md:394 empty placeholder
47	Do you provide mechanisms to securely distribute updates for your products with digital elements?	Partially	VH-7	Claim 9 — fails open, nothing signed
48	Do you ensure vulnerabilities are fixed or mitigated in a timely manner through updates?	No	VH-2	No SLA, no changelog, no tags

#	Question (verbatim from CyberFort)	Answer	Objective	Evidence to attach
49	Where applicable, are security updates distributed in an automatic manner?	Partially	VH-7	Agent yes, manager no
50	Do you disseminate security updates without delay when they are available to address identified security issues?	No	VH-8	No release process
51	Are security updates provided free of charge (unless otherwise agreed for tailor-made products)?	Partially	VH-8	Implied by licensing but undeclared
52	Do you accompany security updates with advisory messages providing users with relevant information?	No	VH-8	release_notes = 'Bug fixes and improvements'

💡 Use **Suggest from Scans** and **AI Suggest Answers** in the Assessments toolbar on at least Q13, Q38 and Q39 — the OSV and SBOM Generator results feed them directly, and demonstrating that the platform pre-populates answers from scanner output is a core part of the pilot.

What the engineer actually clicks (assessment flow)

1. **Assessments** → **+ New Assessment** — Framework: **CRA**, Assessment Type: **Conformity**, Scope Type: **Asset / Product**, Asset: **SEUXDR**, Name: **SEUXDR CRA Conformity Assessment**.
2. **Click the new card** under *Active Assessments* — the questionnaire opens with 52 questions paginated 10 per page. Each question shows **Mandatory: YES**, a **Completed** flag, **Yes / No / Partially / N/A** radios, an **Assign Policy** selector, an **Evidence Description** box and **Attach File(s)**.
3. **For each of the 52 questions** pick the answer from the table above, write the evidence description, assign the governing policy, attach the scan output or document, then **Save Answer**. The **Completed** flag flips to **YES**.
4. **Frameworks** → **Objectives** — select **CRA**, scope **Asset / Product** → **SEUXDR**, and set the **Compliance Status** for all 30 objectives per the coverage matrix. Upload evidence against each.
5. **Export PDF** from the Assessments toolbar, and **Export PDF** from Compliance Chain → Gap Analysis.

The combined exports — conformity questionnaire, objective tree, risk register, gap analysis, SBOM and VEX statements — form the **Annex V technical documentation skeleton** and the input to the Article 28 EU Declaration of Conformity.

Why this matters in the proposal context

The CYBERFORT project (DIGITAL-ECCC-2024-DEPLOY-CYBER-06) targets micro and small enterprises that must demonstrate CRA compliance before placing products on the EU market. Clone Systems is exactly that profile, and SEUXDR is exactly that product: an **Annex III Class I** important product with digital elements, built by an SME, aimed at the EU SME security market.

The value the pilot demonstrates is not that the platform found bugs — Semgrep and OSV find bugs. It is that a **two-person engineering team produced, in a day, a complete and defensible regulatory position** on all 30 CRA objectives and all 52 conformity questions, with every answer traceable to a file and line, a quantified readiness score, the SBOM the Regulation requires, a VEX statement set, a technical-file structure, and a ranked remediation backlog with the four items that block market placement at the top. Reaching the same position through a consulting engagement is several weeks of work and a five-figure fee, and it produces a document rather than a live compliance chain that can be re-run after every release.

The uncomfortable half of the result is the honest half: the product as it stands cannot be CE-marked. Learning that from your own platform, before a notified body or a market-surveillance authority learns it, is precisely the outcome CYBERFORT exists to produce.